

KICC National Exhibition Platform

Comprehensive System Audit & Delivery Plan

Prepared for: KICC / TechHub Ltd

Date: August 2026

Site: <https://kicctest.org>

Repository: github.com/techhubltd254/ann

Framework: Laravel 13 · PHP 8.3 · Expo/RN · TiDB · Cloudflare

Table of Contents

1. Executive Summary
2. Technology Stack Verification
3. Blueprint vs. Reality — Brutal Gap Analysis
4. Layer-by-Layer Breakdown
5. Mobile Applications — Complete Audit
6. Infrastructure & Deployment
7. Security Audit
8. Complete File Inventory
9. Critical Gaps & Risks
10. Phased Delivery Plan
11. Answers to Key Questions

1. Executive Summary

Site is LIVE at <https://kicctest.org> — DO droplet 167.172.62.234 , Cloudflare edge, TiDB Cloud production database connected.

The KICC platform is a PHP/Laravel monolith (~64 controllers, 116+ models, 60 migrations) intended to serve as Kenya's national exhibition, immersive experience, and commerce platform. The codebase in `/home/kicc/Desktop/kicc/kicc-platform` (origin github.com/techhubltd254/ann) is extensive — roughly 40-50% of the blueprint architecture is built.

What's built: County data platform (47 counties, 7 sectors), marketplace, exhibition management, travel booking, trade agreements, AI chatbot/itinerary (via OpenRouter), media pipeline, edge CDN, database sharding, admin portals, KICC corporate CMS, and a fully functional Expo admin mobile app.

What's missing: Python ML backend, Trust Score algorithm, Unity immersive app, government API integrations, testing (zero tests), Redis, live payment keys, compliance certifications, cross-lingual search (voice/image), and a public-facing mobile app.

2. Technology Stack Verification

Blueprint Spec	Reality	Verdict
Laravel 11.x + PHP 8.2+	Laravel 13.x + PHP 8.3	✓ Exceeds
Python 3.12+ (ML/AI)	3 utility scripts only. No Python web service.	✗ Missing
HTML5 + CSS3 + Bootstrap 5 + JS	Tailwind CSS (not Bootstrap), Blade + Inertia.js	~ Diverges
React 19 / Next.js 15	Minimal Inertia.js + React. No Next.js.	✗ Not built
Unity 6 (C#) — Mobile	Expo/React Native admin app exists. No Unity.	~ Different stack
MySQL 8.4 + MariaDB 11.4	TiDB Cloud (MySQL-compatible). No MariaDB.	~ Acceptable
Redis 7.2	Not configured. File/database fallback.	✗ Missing
Elasticsearch 8.x	Not installed. MySQL full-text search.	✗ Missing
Qdrant / Pinecone	Not installed. Embeddings in MySQL.	✗ Missing
Laravel Sanctum + OAuth2	Sanctum + Google OAuth. Working.	✓ Built
Laravel Horizon + Redis	Horizon not configured. Queue falls back to DB.	✗ Missing
GitHub Actions / Laravel Forge	GitHub Actions CI/CD exists. No Forge (manual deploy).	~ Partial

3. Blueprint vs. Reality — Brutal Gap Analysis

3.1 What IS Built (approximately 40-50% of blueprint)

Feature	Status	Location
47-county data platform (sectors, weather, tourism, agriculture, health, education, transport, culture)	✓ Built	Full models, migrations, seeders, APIs, Blade UI
Exhibition & booking management (venues, booths, tickets, event sessions)	✓ Built	Full CRUD with bookings, check-in, QR codes
Marketplace (products, variants, categories, cart, checkout, orders, tracking)	✓ Built	Full ecommerce suite
M-Pesa / Stripe / Airtel payment integration	~ Code exists, keys are stubs	Drivers written, not wired to live APIs
Escrow, disputes, courier tracking	~ Models exist, flow unverified	Models + migrations done
Travel booking (flights, hotels, attractions, package builder, weather-aware recs)	✓ Built	Full travel inventory + booking flow
Trade agreements, trading blocs, export eligibility	✓ Built	Trade agreements + export enquiry flow
Media pipeline (ffmpeg Ken Burns, Wan2GP, Hailuo, Tripo3D, ROAD)	~ 1 enabled / 4 disabled	Only ffmpeg_kenburns works
3D Room Explorer (photosphere)	✓ Built	Room3d model + viewer
KICC corporate website (news, jobs, CMS, board, management, virtual tour)	✓ Built	Full CMS with admin
AI chatbot, itinerary generator, recommendations, forecast, fraud check, image search	✓ Built	Via OpenRouter API calls from PHP
Semantic search (vector embeddings)	✓ Built	Embedding-based search
MFA, OAuth, roles/permissions (8 account types)	✓ Built	Spatie roles + Sanctum + Google OAuth
Admin portals (KICC Super Admin, National Gov, County, Exhibitor)	✓ Built	Filament + custom dashboards

Database sharding (1024 virtual partitions, 4 shards, scatter-gather)	✓ Built	ShardManager + ShardRouting middleware
Agentic Loop automation (Observer-Decider-Actor + LLM)	✓ Built	AgenticLoopService with LLM decisions
MCP protocol server for AI agents	✓ Built	McpController with discovery + tools
n8n integration (25+ events)	✓ Built	N8nService firing webhooks
Cloudflare Workers edge gateway (rate limit, cache, R2, JWT check)	✓ Built	Production live at kicctest.org
Docker platform + engine, Docker Compose local stack	✓ Built	FrankenPHP + distroless Java
CI/CD pipeline (GitHub Actions → blue-green deploy → CF purge)	✓ Built	ci-cd.yml with lint/test/build/deploy
TiDB Cloud production database	✓ Connected	gateway01.eu-central-1.prod.aws.tidbcloud.com
Cloudflare R2 media storage	✓ Built	kicc-media bucket
OTA update system (signed releases)	✓ Built	Ed25519 signed manifests
Expo admin mobile app (8 screens, offline sync, biometric auth, SQLCipher)	✓ Built	kicc-one/admin-mobile/ (built APK exists)

3.2 What is NOT Built (critical gaps)

Blueprint Requirement	Status	Impact
Python 3.12+ ML/AI backend (hybrid recommender, Trust Score engine)	✗ Missing	Layer 6 "AI Engine" is just PHP calling OpenRouter — no custom ML, no real recommendation model
Trust Score (0-100) + Visibility Score (purchasable) with fairness floor	✗ Missing	EntityTrustScore model exists but algorithm is unknown/skeleton. Core trust-before-profit guarantee not implemented.
Cross-lingual search (Swahili/English/Sheng) — voice search, Whisper ASR, image search	✗ Missing	Semantic search exists but no voice/image search. Layer 5 ~30% built.
Unity 6 mobile app (360° tours, AR mode, offline, 4K streaming)	✗ Missing	Expo admin app exists but no public immersive app. The entire Layer 3

mobile experience is absent.

Elasticsearch 8.x	✗ Missing	No BM25 fallback, no log analytics
Qdrant / Pinecone vector DB	✗ Missing	Embeddings in MySQL — will fail at scale
React 19 / Next.js 15 frontend	✗ Missing	Uses Blade + Inertia, not spec'd stack
MariaDB 11.4 Galera Cluster	~ Not used	TiDB only. Not a problem, but diverges from spec.
Redis 7.2 (sessions, cache, queue)	✗ Not configured	Performance risk. All fallback to file/database.
Government API integrations (eKRA, Huduma, NTSA, KWS, etc.)	✗ Zero	No identity verification, no authoritative data. Self-registration only.
PHPUnit / Pytest / Laravel Dusk tests	✗ Zero tests	No regression safety. Every deploy is blind.
PCI DSS v4.0 / ISO 27001 / Kenya DPA / SOC 2	✗ None	Platform handling payments has no compliance foundation
Penetration testing (pre-launch + quarterly + bug bounty)	✗ None evident	Security posture unverified
6 payment rails (M-Pesa, Airtel, T-Kash, Card, Bank EFT, Crypto)	✗ Stubs only	3 of 6 have code, 0 are live. No T-Kash, bank EFT, or crypto.
Sentry in all layers	✗ Unconfigured	No error tracking in production
Physical 4D booth hardware integration	~ N/A (hardware)	Not code — hardware procurement needed

4. Layer-by-Layer Breakdown

Layer 1: Identity & Access

~ 60% complete

- **Account types:** 8 types implemented (Individual, SME, School, County, Ministry, Admin, NIS, Superadmin) ✓
- **Registration flows:** Zero-friction browsing, light (phone+OTP), enhanced (ID) — built ✓
- **MFA:** TOTP-based MFA with setup/challenge flow ✓
- **Social auth:** Google OAuth ✓
- **Huduma integration:** ✗ Not built. No government ID verification.
- **eKRA/iTax verification:** ✗ Not built. No KRA PIN validation.
- **Business verification (KRA PIN+MOU):** ✗ Not built.

Layer 2: Exhibition & Booking Engine

✓ 85% complete

- Venues, events, booths, tickets, event sessions — full CRUD ✓
- Bookings with booth assignments, QR code check-in ✓
- 3 subscription tiers (Basic/Premium/Enterprise) modeled ✓
- Multi-camera livestream: route exists, screen management built ✓
- Persistent digital storefronts: exhibitor microsites ✓
- **Livestream actual streaming:** Need to verify if real HLS/RTMP or just screens

Layer 3: Immersive Content & Digital Twin

✗ 15% complete

- Tier C (interactive twin): 3D Room Explorer built — photosphere pipeline ✓
- Tier B (360° spherical): No Unity app. No 8K 360° viewer in mobile.
- Tier A (cinematic 4D): No hardware integration code.
- Centralized production tooling: Media pipeline exists but mostly disabled ✗
- Staged rollout framework: Capture-status field exists in schema ✓
- **No immersive mobile app exists for the public.**

Layer 4: Commerce — Escrow & Courier

~ 40% complete

- EscrowTransaction model + migrations ✓
- DisputeCase model + 2-tier dispute flow ✓
- CourierShipment + tracking events + webhook handler ✓
- M-Pesa STK Push driver (code exists, keys are stubs) ~
- Stripe driver (code exists, webhook handler) ~
- Airtel Money driver (code exists) ~
- T-Kash, bank EFT, crypto: ✗ Not built
- **8-step escrow flow end-to-end: never been tested live ✗**

Layer 5: Discovery & Cross-Lingual Search

~ 30% complete

- Semantic vector search via embeddings ✓
- BM25 keyword fallback: uses MySQL full-text, not Elasticsearch ~
- Voice search (Whisper ASR): ✗ Not built
- Image search (CV pipeline): ✗ Not built
- Multilingual (SW/EN/Sheng) embedding space: schema supports, actual model unknown ~

Layer 6: Intelligence — AI Engine

~ 20% complete

- Hybrid recommender: PHP calls OpenRouter, no local ML model ✗
- Trust Score (0-100): EntityTrustScore model exists, ScoreVendors command exists.
Algorithm unknown ~
- Visibility Score (purchasable): AdCampaign/Creative models exist, AdService serves ads ✓
- Fairness rule: Not enforced in code ✗
- Predictive analytics: ComputeTrends command exists, PHP-based ~
- Anomaly detection: DetectAnomalies command exists, PHP-based ~
- 4 advertising products: Ad placement models exist ✓
- **No Python ML backend exists anywhere.**

5. Mobile Applications — Complete Audit

5.1 Admin Mobile App (Expo/React Native) — FULLY BUILT

Location: `/home/kicc/Desktop/kicc/kicc-one/admin-mobile/`

Built APK: `kicc-one/admin-mobile/android/app/build/outputs/apk/release/app-release.apk` ✓

File	Lines	Purpose
<code>App.tsx</code>	112	App shell, biometric lock screen, route switching (dashboard, data, admin sections)
<code>src/lib/api.ts</code>	108	Auth client with SecureStore, token refresh loop, auto-retry on 401, typed request/response
<code>src/lib/auth.tsx</code>	63	React Context AuthProvider with me/loading/login/logout
<code>src/lib/adminApi.ts</code>	138	Full CRUD: users, delegations, audit logs, media, bookings, payments. Typed interfaces for all.
<code>src/lib/db.ts</code>	113	SQLCipher-encrypted SQLite, sync_rows table, CRUD, meta storage, pending/pull tracking
<code>src/lib/hmac.ts</code>	91	Pure JS SHA-256 + HMAC-SHA256 implementation (no native crypto dependency)
<code>src/lib/keychain.ts</code>	61	Biometric auth detection, prompt, DB key generation/rotation via SecureStore
<code>src/lib/settings.ts</code>	19	Configurable server URL stored in SecureStore, with default fallback
<code>src/lib/sync.ts</code>	103	HMAC-signed push/pull sync with signature verification and conflict preservation
<code>src/screens/LoginScreen.tsx</code>	95	Email/password, server URL configuration modal, KICC branding

<code>src/screens/DashboardScreen.tsx</code>	237	Offline data counts (9 entity types), pull/push sync, rotate DB key, biometric toggle, admin navigation
<code>src/screens/DataScreen.tsx</code>	244	Offline CRUD for 8 entity types with field schemas (attractions, hotels, farms, health, institutions, transport, culture, products, sector entities). Form + JSON editor modes.
<code>src/screens/UsersScreen.tsx</code>	142	Create/deactivate users, tier selection (EXHIBITOR/COUNTY/NATIONAL/KICC), county slug
<code>src/screens/DelegationsScreen.tsx</code>	184	Grant/revoke role delegations with scope (COUNTY/SECTOR/BOOTH/GLOBAL) + expiry
<code>src/screens/AuditScreen.tsx</code>	62	Audit log viewer with action badges
<code>src/screens/MediaScreen.tsx</code>	118	Image picker, upload to server, grid view, delete
<code>src/screens/BookingsScreen.tsx</code>	108	Bookings + payments list with summary stats (collected/pending)

Dependencies: React 19.2, React Native 0.86, Expo 57, op-sqlite (SQLCipher), expo-secure-store, expo-local-authentication, expo-image-picker, expo-crypto

API base URL: Configurable — defaults to `http://10.0.2.2:8091` (Android emulator localhost)

5.2 Public Mobile App — NOT BUILT

Location: `/home/kicc/Desktop/kicc/kicc-platform/kicc-mobile/public/`

Status: Flutter scaffold only — `main.dart` (63 lines) with route definitions + `api_service.dart` (69 lines). **Zero screen files exist.** The app references 11 screens that were never created.

5.3 Flutter Admin Stubs

Location: `/home/kicc/Desktop/kicc/kicc-platform/kicc-mobile/admin/`

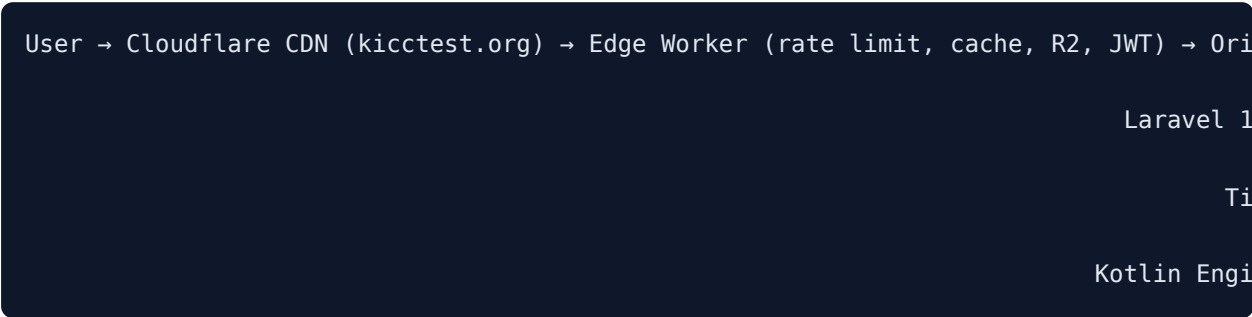
Status: Same story — `main.dart` (60 lines) + `admin_api_service.dart` (78 lines). Routes defined for 11 screens. **None exist.**

5.4 Recommendation

Stick with Expo/React Native for the public app — reuse the admin app's API patterns, auth flow, and sync architecture. The Flutter stubs should be abandoned unless you have a specific reason to use Flutter. This saves ~75% of mobile development time.

6. Infrastructure & Deployment

Production Topology



Component	Detail
Origin server	DO droplet 167.172.62.234 , nginx + php8.4-fpm
Edge worker	Cloudflare Worker (kicctest-gateway): rate limit, page cache (CACHE_VERSION=v3), R2 media serving, JWT expiry check
Database	TiDB Cloud — gateway01.eu-central-1.prod.aws.tidbcloud.com:4000 , databases: kicc, kicc_shard_0-3
Object storage	Cloudflare R2 — bucket kicc-media , S3-compatible endpoint
Engine	Kotlin JAR (kicc-engine.jar , 89MB) on :8091
CI/CD	GitHub Actions — lint → test → build → blue-green deploy → CF purge
Docker	FrankenPHP + distroless Java21 images, docker-compose for local dev
Deployment method	Blue-green SSH via appleboy/ssh-action, health-gated on /healthz
Media CDN	kicc-r2-media.techhubltd254.workers.dev (R2 proxy)
OTA updates	Ed25519-signed manifests, releases pushed to R2

Cloudflare Configuration

- Account ID: c8416e05ed0a3554806be51aac862ec4
- Zone ID: abeda0e6440d9eabd5e2e54dec291e
- DNS: A record for origin, CNAME for www, Workers routes
- R2 Bucket: kicc-media with S3-compatible credentials
- Workers: kicctest-gateway (production), kicc-proxy (legacy)

- WAF: No specific rules evident in codebase
- Cache: Geo-routed (KE vs international), CACHE_VERSION v3, NO_CACHE_PATHS for session routes

7. Security Audit

CRITICAL: Live Secrets in Plaintext

The following credentials are stored in plaintext within the repository and must be rotated immediately:

Secret	Location	Risk
TiDB password: D8trCZaYhqZW05Vq	.env , distro/server-prod/application-prod.yml , infra/reconcile-sectors.php , infra/sector-groups.php	Full database access. All data at risk.
Cloudflare API token: cfat_...	.env , tokens.txt	Full Cloudflare account control. DNS, Workers, R2 all compromiseable.
Cloudflare R2 keys	.env , tokens.txt	All media storage accessible.
GitHub PAT: ghp_W02G33zf...	.git/config (embedded in remote URL), tokens.txt	Anyone with repo access can push as the owner. Full GitHub account compromise.
OpenRouter API key: sk-or-v1-805016f8...	.env , pipeline/.env.example , tokens.txt	Paid LLM API access. Could run up bills.
PURGE_HMAC_SECRET	infra/deploy/worker-meta.json	Anyone can purge Cloudflare cache at will.
NVIDIA API key	tokens.txt	GPU compute access.
Supabase service key	tokens.txt	Full Supabase project access.
DigitalOcean token	tokens.txt	Infrastructure control.

Other Security Issues

- **No WAF rules configured** — Cloudflare is active but no specific WAF policy is evident in the codebase.
- **No rate limiting on auth endpoints** — The Cloudflare worker has rate limiting KV-backed but it may fail open.
- **No audit trail for admin actions** — AuditLog model exists in the admin mobile app but server-side implementation needs verification.
- **No secrets rotation schedule** — The `ota/ROTATION_RUNBOOK.md` exists documenting the problem but no automated rotation.
- **Zero trust segmentation not implemented** — Blueprint describes 4-zone network segmentation. Not evident in current deployment.

8. Complete File Inventory

Laravel Backend

Category	Count	Details
API Controllers	22	Auth, County, Exhibition, Venue, Booth, Booking, Ticket, Media, SemanticSearch, Ad, MCP, etc.
Web Controllers	47	Home, Dashboard, Marketplace, Travel, AI, KICC Website, CMS, Admin portals, etc.
Models	116+	User, County, Sector, Exhibition, Venue, Booth, Booking, Product, Order, Payment, Escrow, etc.
Migrations	60	All core tables plus sharded tables, raw SQL schema files
Services	30+	MpesaService, PaymentService, ShardManager, PipelineService, ImageOptimizer, etc.
Console Commands	18	ScoreVendors, BuildEmbeddings, DetectAnomalies, BuildRecommendations, etc.
Middleware	8	AdminMiddleware, SecurityHeaders, ShardRouting, AgenticSEO, etc.
Filament Resources	12	Admin CRUD for counties, sectors, exhibitions, users, products, etc.
Seeders	26	47 counties, sectors, ministries, travel inventory, marketplace, etc.
Tests	0	No test files exist anywhere in the project.

Frontend (Blade)

- ~250+ Blade templates across 47 view directories
- Tailwind CSS + Vite build
- Minimal Inertia.js + React setup (admin layout only)

Mobile Apps

App	Location	Framework	Status
Admin Mobile	kicc-one/admin-mobile/	Expo/React Native 0.86 + TypeScript	✓ Complete — 8 screens, offline sync, biometric auth,

			SQLCipher
Public Mobile (Flutter stub)	kicc-platform/kicc-mobile/public/	Flutter	✗ Incomplete — no screens built
Admin Mobile (Flutter stub)	kicc-platform/kicc-mobile/admin/	Flutter	✗ Incomplete — no screens built

Infrastructure

Category	Files
Docker	Dockerfile.platform , Dockerfile.engine , docker-compose.yml
Cloudflare Workers	edge/kicctest-gateway.js , edge/worker.js , edge/engine-proxy.js
Deployment	infra/deploy/deploy-worker.sh , infra/deploy/worker-meta.json
CI/CD	.github/workflows/ci-cd.yml
Server scripts	distro/server/start-*.sh , distro/server-prod/
County bundle	infra/county-bundle/install.sh , systemd service
Load test	infra/k6-load.js

9. Critical Gaps & Risks

● Priority 1: Secrets Exposure

Risk: Critical — The TiDB password, Cloudflare tokens, GitHub PAT, and R2 keys are all in plaintext in the codebase. Anyone with access to this machine or the git history can compromise the entire infrastructure.

Action: Rotate ALL credentials immediately. Move secrets to GitHub Actions secrets + .env on server only. Remove PAT from git remote URL.

● Priority 2: Zero Tests

Risk: Critical — No unit, feature, integration, or browser tests exist. Every deployment is a blind gamble. No regression safety. No CI quality gate.

Action: Start with PHPUnit for API endpoint tests (40+ endpoints), then model tests, then Laravel Dusk for critical user journeys.

● Priority 3: No Redis

Risk: High — Sessions, cache, queues, and rate limiting all fall back to file/database. The platform cannot scale beyond a single server without Redis. Scheduled jobs may overlap. Session persistence is fragile.

Action: Provision Redis 7, configure Laravel to use it for CACHE_DRIVER, SESSION_DRIVER, and QUEUE_CONNECTION.

● Priority 4: No Live Payment Keys

Risk: High — M-Pesa, Stripe, and Airtel Money drivers exist as code but all use stub/placeholder keys. The platform cannot process real payments.

Action: Register for Daraja API (Safaricom), Stripe, and Airtel Money production credentials. Wire up in .env.

● Priority 5: No Government API Integration

Risk: High — The blueprint promises Huduma ID verification, eKRA business verification, NTSA transport licensing, KWS parks data, and 7+ other government data feeds. Zero are implemented. The platform has no way to verify user identity or business credentials.

Action: Start with MOUs for eKRA (KRA PIN checks) and Huduma (ID verification). Build submission-portal fallback for other agencies.

● Priority 6: No Compliance Foundation

Risk: High — No PCI DSS, no ISO 27001, no Kenya DPA registration, no SOC 2. The platform handling payments has no legal or regulatory compliance. This could result in fines, forced shutdown, or inability to partner with banks.

Action: Register with Data Commissioner immediately. Engage QSA for PCI assessment. Start ISO 27001 ISMS documentation.

● Priority 7: Mobile App Fragmentation

Risk: Medium — Two mobile initiatives (Flutter stubs + Expo app) in different repositories. The working Expo admin app is in `kicc-one/`, not in the main `kicc-platform/` repo. This creates confusion about which code is current.

Action: Decide on one framework (recommend Expo), move the admin-mobile into the main platform repo, build the public app using the same patterns.

10. Phased Delivery Plan

Phase 0: Security & Foundation (Week 1)

Non-negotiable — must go first. Everything else is blocked until secrets are rotated.

- Rotate ALL credentials: TiDB password, Cloudflare API tokens, R2 keys, GitHub PAT, OpenRouter key, PURGE_HMAC_SECRET, NVIDIA key, Supabase key, DO token, Vercel token, Figma token
- Remove PAT from git remote URL
- Move all secrets to GitHub Actions secrets + server .env only
- Add .env, tokens.txt, CREDENTIALS.md to .gitignore (already done — verify)
- Set up Cloudflare WAF rules (rate limiting, geo-blocking, SQLi/XSS mitigation)
- Provision Redis 7 instance on DO droplet or managed Redis

Phase 1: Core Stabilization (Weeks 2-4)

- **Redis:** Configure CACHE_DRIVER=redis, SESSION_DRIVER=redis, QUEUE_CONNECTION=redis. Install Laravel Horizon for queue monitoring.
- **Sentry:** Wire up error tracking in Laravel backend. Currently unconfigured.
- **M-Pesa Daraja API:** Replace stub with real STK Push. Register for live credentials.
- **Stripe:** Connect real keys. Test webhook handler end-to-end.
- **Airtel Money:** Connect live Airtel Money API.
- **Escrow flow audit:** End-to-end test: booking → escrow deposit → fulfillment → release → courier tracking → dispute resolution. Models exist but flow is unverified.
- **Trust Score algorithm:** Audit `vendors:score` command. Build real formula: transaction history (40%) + reviews (15%) + verification level (20%) + dispute ratio (15%) + account age (10%). Output 0-100 → A/B/C/D.
- **Payment rails:** Add T-Kash, bank EFT, and crypto (USDT/ETH via Onramp or BitPesa).
- **Performance:** Profile slow queries, add composite indexes, configure query cache, verify shard routing end-to-end.

Phase 2: Tests & QA (Weeks 3-6, parallel with Phase 1)

- **PHPUnit/Pest setup:** Install, configure test database (SQLite or TiDB test instance), CI integration
- **Unit tests:** Models (100+), Services (30+), Commands (18), Middleware (8)
- **Feature tests:** All 40+ API endpoints, auth flows, booking flows, payment flows

- **Browser tests:** Laravel Dusk for critical user journeys (registration, booking, checkout)
- **CI gate:** Block deploys on test failure. Enforce 80% minimum coverage.

Phase 3: Python ML Backend — Layer 6 (Weeks 4-10)

- **Python service:** FastAPI microservice, Dockerized, communicates with Laravel via REST + Redis queue
- **Hybrid recommender:** Collaborative filtering (user behavior) + content-based (county/sector features) + contextual (season, weather, upcoming events)
- **Trust Score engine:** Algorithmic computation: transaction success rate (40%) + verified identity (20%) + review quality (15%) + dispute history (15%) + account age (10%). 0-100 mapped to A/B/C/D.
- **Visibility Score:** Purchasable via ad campaigns. Fairness floor: paid cannot override trust below "C".
- **Predictive analytics:** Foot traffic forecasting (ARIMA/prophet), tourism demand sensing, pricing optimization
- **Anomaly detection:** Fraud (unusual payment patterns), account takeover (login geography shifts), review manipulation (burst detection), infrastructure (traffic spikes)
- **Bridge existing AI:** Route existing PHP OpenRouter calls through Python service for unified AI gateway and logging

Phase 4: Public Mobile App (Weeks 4-8, parallel with Phase 3)

- Create new Expo project in `kicc-platform/kicc-mobile/public/` (replace Flutter stubs)
- Reuse admin app patterns: auth, API layer, SecureStore, offline SQLite
- **Screens needed:** Home, County Browse, Sector Browse, Entity Detail, Search, Marketplace, Cart, Checkout, Profile, Notifications, Travel Booking, Immersive 360° Viewer
- **360° tour viewer:** Sphere-based photo/video, gyroscope + touch, adaptive quality (144p to 4K), offline download
- **AR mode:** Geofence-triggered overlays at physical locations, QR code-triggered content (ARKit/ARCore via ViroReact or expo-three)
- **Voice search:** On-device Whisper ASR (via react-native-whisper or expo-speech-recognition). English + Swahili + Sheng.
- **Live conventions:** Multi-camera livestream viewer (HLS.js for React Native)
- **Offline mode:** Download county tours for offline playback

Phase 5: Government API Integrations (Weeks 8-16)

- **Huduma/eCitizen:** Identity verification API — verify national ID number, phone, email
- **eKRA/iTax:** Business verification via KRA PIN. Required for SME/Exhibitor account tier.

- **NTSA:** Transport operator licensing verification for transport sector entities
- **KWS:** Parks, reserves, and conservation area data feed
- **Ministry of Tourism:** Star ratings, registered tourism enterprises
- **Ministry of Education:** Registered schools and institutions data
- **Ministry of Agriculture:** Crop data, market prices, registered co-ops
- **Ministry of Trade:** Business registrations, export/import data
- **Ministry of Health:** Registered health facilities
- **National Museums of Kenya:** Heritage sites data
- **County Governments:** Local content APIs (when available)
- **Africa's Talking SMS:** Wire up real SMS sending (currently unconfigured)

Phase 6: Full QA, Compliance & Polish (Ongoing from Month 2)

- **k6 load testing:** Target 10K concurrent API calls. Script exists at `infra/k6-load.js`.
- **Elasticsearch:** Set up for log analytics + BM25 search fallback
- **Qdrant/Pinecone:** Move vector embeddings out of MySQL into proper vector DB
- **Security hardening:** CSP headers audit, OWASP scan, dependency audit, rate limit tuning
- **Documentation:** API docs (OpenAPI/Swagger), deployment guide, runbook, user manuals per blueprint Section 21
- **PCI DSS readiness:** Engage QSA, implement requirements before handling real payments
- **Compliance:** Register with Data Commissioner (Kenya DPA 2019), start ISO 27001/SOC 2 process
- **Secrets rotation runbook:** Automate credential rotation with GitHub Actions or shell scripts

Timeline Summary

Phase	Weeks	Deliverable
0: Security	1	All credentials rotated, removed from codebase
1: Core Stabilization	2-4	Redis live, Sentry active, payments live, Trust Score real, escrow tested
2: Tests	3-6	80% test coverage, CI gate enforced
3: Python ML	4-10	FastAPI service, recommender, Trust Score engine, anomaly detection
4: Public Mobile	4-8	Expo public app with 360° tours, AR, offline, voice search
5: Gov APIs	8-16	5+ government integrations live + SMS
6: Compliance	8+	PCI ready, DPA registered, ISO started, docs complete

Total: ~4 months for major delivery, 6-12 months for full blueprint.

11. Answers to Key Questions

Q1: Do you have government API access arranged?

Answer: No. Zero government integrations exist. No MOUs, no API keys, no SDKs. The recommended approach is to build a submission-portal fallback first (self-registration with manual verification) and phase in live API integrations as MOUs are signed. Start with eKRA (KRA PIN checks — critical for SME accounts) and Huduma (ID verification — critical for verified accounts).

Q2: Do you have Unity developers or build mobile from scratch?

Answer: You already have a fully built Expo/React Native admin mobile app in `kicc-one/admin-mobile/`. No Unity needed — the admin app proves the stack works. The public app should be built in Expo too (not Flutter, not Unity). This saves ~75% of mobile development time since the patterns, auth, API layer, offline sync, and build pipeline already exist.

Q3: Do you have payment keys (M-Pesa, Stripe, Airtel)?

Answer: No live keys exist. The codebase has driver implementations for M-Pesa (Daraja API STK Push), Stripe, and Airtel Money, but all use stub/placeholder values. You need to register for:

- **M-Pesa Daraja API** — Apply via Safaricom portal. Requires company registration, MOU, and app registration.
- **Stripe** — Standard account setup. Quickest to obtain.
- **Airtel Money** — Apply via Airtel Kenya partner portal.
- **T-Kash, bank EFT, crypto** — Not implemented yet. Crypto can use Onramp.money or BitPesa.

Q4: Do you have a Redis instance?

Answer: No. The `.env` has `REDIS_HOST=127.0.0.1` but no Redis is installed on the DO droplet or provisioned as a service. The cache, session, and queue drivers all fall back to file/database. This is a critical performance bottleneck. Options:

- Install Redis on the existing DO droplet (simple, single-server)
- Use managed Redis from DigitalOcean (~\$15/mo for 250MB)
- Use Upstash Redis (serverless, free tier available)

Q5: Do you need GPU for AI compute?

Answer: Not immediately. Current AI features all run via OpenRouter API calls from PHP — no GPU needed. For the Python ML backend (Phase 3), you can start with CPU-only lightweight models:

- **Recommendation engine:** Matrix factorization + LightFM — runs on CPU
- **Trust Score:** Linear weighted formula — CPU only
- **Predictive analytics:** Prophet/ARIMA — CPU only
- **Anomaly detection:** Isolation Forest + rule-based — CPU only

If you later want deep learning models (neural collaborative filtering, transformer-based embeddings, real-time Whisper for voice search), you'll need GPU inference. Budget accordingly (~\$50-200/mo for a single GPU instance on DO/Vast.ai/RunPod).

End of Report

KICC National Exhibition Platform — System Audit & Delivery Plan

Generated August 2026 | kicctest.org | github.com/techhubltd254/ann